

Designing the plan: runbooks, OpsCenter and Automation

Domain 2 opens here. Writing the response before you need it, and encoding it so it runs the same way every time.

A response plan that lives in a document is a **hope**. A response plan that lives in code is a control.

The four phases, and where the work actually is

- ◆ **Prepare** – access, tooling, logging, blast radius, tested runbooks. Almost all of the real work lives here.
- ◆ **Detect and analyse** – domain 1, plus validating a finding's true scope and impact.
- ◆ **Contain, eradicate, recover** – isolate first, remove the cause, then restore. In that order.
- ◆ **Post-incident** – root cause, and feeding the lesson back into preparation.
- ◆ The exam tests **preparation** hardest, because that is the phase where architecture decisions get made.

ON THE EXAM

You cannot prepare during an incident. Anything a scenario says the team 'will do when it happens' is a preparation failure.

Runbook or playbook?

RUNBOOK

Steps to perform

- Prescriptive and mechanical
- Isolate this instance, snapshot that volume
- The natural candidate for automation
- Systems Manager Automation document

PLAYBOOK

Decisions to make

- Investigative and conditional
- Is this real? What is the blast radius?
- Needs judgement, so it needs a human
- A notebook, or a documented procedure

THE TIEBREAKER

Automate the runbook. Support the playbook. Trying to automate judgement is how automated response causes outages.

Systems Manager OpsCenter

- ◆ Central place for **OpsItems** – operational work items with the affected resource, related data and remediation attached.
- ◆ Created from **EventBridge** rules, **CloudWatch** alarms, **Security Hub** findings or **Config** changes. Or by hand.
- ◆ OpsItems **deduplicate**, so a hundred findings about one instance become one work item rather than a hundred pages.
- ◆ You can attach **Automation runbooks** directly to an OpsItem and run them from the work item.
- ◆ **Named explicitly in exam guide skill 2.1.1** as the example for response plans and runbooks.

ON THE EXAM

The exam guide names OpsCenter. That is not a coincidence, and the next slide explains why.

Why OpsCenter and not Incident Manager

- ◆ Incident Manager closed to new customers on 7 November 2025, and gets no new features.
- ◆ AWS recommends **OpsCenter** for operational issues, and partner tools for paging.
- ◆ SCS-C03 went live 2 December 2025. The guide names OpsCenter and **never names Incident Manager**.
- ◆ Study material still teaching Incident Manager is teaching a distractor.
- ◆ **AWS Security Incident Response** is a real service, but is **not in the in-scope list**.

ON THE EXAM

An answer that was correct in 2024 is a distractor in 2026.

Systems Manager Automation

- ◆ An **Automation document** is a runbook as code – steps, inputs, branching, approvals, error handling.
- ◆ Hundreds of **AWS-owned documents** exist already. Write custom ones for your own procedures.
- ◆ It runs with an **IAM service role**, so the automation's permissions are separate from the responder's.
- ◆ Triggered by **EventBridge, Config remediation, OpsCenter, Security Hub custom actions**, or a schedule.
- ◆ An **approval step** pauses for a named principal. Automation with a human gate.

ON THE EXAM

The approval step is underrated: automate the mechanical steps, keep a person in the loop.

From finding to tracked, actionable work

01

Finding

GuardDuty raises a critical attack sequence finding.

02

EventBridge

A rule matches on severity and finding type.

03

OpsItem

An OpsItem is created, deduplicated against the same resource.

04

Runbook

An Automation document is attached and run, with an approval gate.

05

Record

Every step, approval and output is recorded against the OpsItem.

ON THE EXAM

Notice what this replaces: an email, a Slack message, and somebody's memory of what they did at 03:00.

When one runbook is not enough

- ◆ **Step Functions** orchestrates multi-step response – branching, parallel actions, waits, retries, approval.
- ◆ Right when the response spans **several services or accounts**, or decides as it goes.
- ◆ Keeps **execution state and history**, so you see which branch ran and why. That is your timeline.
- ◆ **Lambda** = one action. **Automation** = one procedure. **Step Functions** = a workflow.
- ◆ The Automated Forensics Orchestrator is built from exactly these pieces. Module 10.

ON THE EXAM

One action is Lambda. One procedure is Automation. A workflow is Step Functions.

SageMaker AI notebooks as investigation runbooks

- ◆ **Named in exam guide skill 2.1.1**, alongside OpsCenter, as an example of response plans and runbooks.
- ◆ A notebook is a **playbook you can execute** – narrative, queries and charts in one versioned artefact.
- ◆ Analysts query CloudTrail, Security Lake or Athena from cells; output stays with the reasoning.
- ◆ Rerunnable and shareable, so a junior analyst follows a senior's method.
- ◆ It is compute in your account. Scoped execution role, outside the workload's blast radius.

ON THE EXAM

Automation encodes what to do. A notebook encodes how to think about it.

When automation makes it worse

- ◆ **Automated termination destroys evidence.** You cannot un-terminate an instance.
- ◆ **A false positive becomes a self-inflicted outage,** and the trigger becomes a DoS button.
- ◆ **Automation needs powerful permissions,** so the response role becomes a target.
- ◆ Automate the **reversible** steps, gate the irreversible ones, log everything.
- ◆ Untested automation is worse than none. That is skill 2.1.3, and module 9.

ON THE EXAM

'Automatically terminate' is nearly always wrong. Containment preserves; eradication destroys.

A logistics company routes all GuardDuty findings to an SNS topic that emails a shared security mailbox. During a recent cryptomining incident, one compromised instance generated 340 findings over six hours, burying two unrelated critical findings for other resources.

The security lead wants each affected resource tracked as a single work item carrying the resource details and the remediation, assigned to an owner, with the runbook runnable from the same place. The company has never used any AWS incident management service before.

What should the security lead implement?

- ☐ A AWS Systems Manager Incident Manager with a response plan and engagement contacts
- ☐ B EventBridge rules creating Systems Manager OpsCenter OpsItems, with Automation runbooks attached
- ☐ C An SNS message filter policy to suppress duplicate findings for the same resource
- ☐ D Security Hub custom actions that email the mailbox with a formatted finding summary

◆ PAUSE AND DECIDE

What should the security lead implement?

A Incident Manager with a response plan
The answer most study material still gives. Incident Manager closed to new customers on 7 November 2025, and this company has never used it, so it cannot sign up.

C SNS message filter policy
Filter policies route messages by attribute; they do not deduplicate by resource or track state. It would still be an inbox with no ownership or runbooks.

B EventBridge to OpsCenter OpsItems with Automation attached
Correct. OpsItems deduplicate per resource, carry resource context and ownership, and runbooks attach directly – every stated requirement, in one service.

D Security Hub custom actions emailing a summary
Custom actions are manually triggered by an analyst on a finding. Better formatting, same shared mailbox, still no work item.

THE SIGNAL

'Has never used any AWS incident management service' is not background. It is the sentence that eliminates option A.

A bank is building automated response for compromised EC2 credentials. The response must: check whether the instance is in production, snapshot its volumes, move it to a forensic security group, revoke the role's active sessions, and open a ticket. Production instances require a named approver before isolation; non-production instances do not.

Some steps take minutes and must be retried on failure. The team wants to see afterwards exactly which path each response took and why.

What should the bank use to orchestrate this?

- ☐ A A single Systems Manager Automation document containing all the steps
- ☐ B An EventBridge rule invoking one Lambda function that performs each action in sequence
- ☐ C A Config rule with automatic remediation triggered by the GuardDuty finding
- ☐ D An AWS Step Functions state machine invoked by EventBridge, calling Automation and Lambda

◆ PAUSE AND DECIDE

What should the bank use to orchestrate this?

- A

 A single Automation document
The closest wrong answer. Automation handles steps and approvals well, but this branches on environment, spans several services, and needs a durable execution record.
- B

 One Lambda doing everything in sequence
Fights the runtime. Lambda has a 15-minute ceiling, no native waiting for human approval, and you would hand-build retries and state.
- C

 Config rule with automatic remediation
Config evaluates configuration compliance. A GuardDuty finding is a behavioural event, not a configuration change, so the trigger does not fit.
- D

 Step Functions invoked by EventBridge
Correct. Branching, parallel steps, waits, retries and a human approval gate, with execution history showing which path ran and why.

THE SIGNAL

Count the requirements: branching, long waits, retries, conditional approval, an audit trail. Five signals, one service.

A healthcare provider's senior analyst has a consistent method for investigating suspected credential compromise: a fixed sequence of CloudTrail and Security Lake queries, cross-referenced against Athena tables, with charts of API call volume by principal over time.

Today it lives in her head and a text file of SQL. The security manager wants the method captured so that any analyst can run the same investigation identically, with the reasoning, the queries and the resulting charts kept together and version controlled.

What should the provider use?

- ☐ A Amazon SageMaker AI notebooks holding the queries, narrative and visualisations
- ☐ B A Systems Manager Automation document running each query as a step
- ☐ C Athena saved queries with a CloudWatch dashboard for the charts
- ☐ D An OpsCenter OpsItem template with the query list in the description

◆ PAUSE AND DECIDE

What should the provider use?

- A

 SageMaker AI notebooks
Correct. A notebook keeps narrative, queries and charts in one versioned, rerunnable artefact. The exam guide names it in skill 2.1.1 for exactly this.
- B

 Automation document running each query
Automation encodes what to do, not how to reason. It has nowhere to put the analyst's narrative and produces no charts.
- C

 Athena saved queries plus a CloudWatch dashboard
Splits the method across two services and loses the reasoning entirely. A dashboard shows a chart; it does not explain what the analyst concluded.
- D

 OpsItem template with queries in the description
OpsCenter tracks work items. A list of SQL in a description field is the text file the provider already has, moved somewhere else.

THE SIGNAL

'Reasoning, queries and charts kept together' describes a notebook. Nothing else on this list holds all three.

A retailer's new security engineer proposes an EventBridge rule that automatically terminates any EC2 instance with a HIGH or CRITICAL GuardDuty finding, arguing this gives the fastest possible containment with no human delay.

The environment is internet-facing, autoscaled, and has previously produced GuardDuty findings from a penetration testing tool run by an approved third party. The security manager asks you to assess the proposal.

What is the BEST assessment?

- ☐ A Sound. Automatic termination is the fastest containment and removes the threat entirely
- ☐ B Sound, provided the rule is limited to CRITICAL findings to reduce false positives
- ☐ C Unsound. Termination destroys forensic evidence and hands an attacker a denial-of-service trigger
- ☐ D Unsound, because EventBridge cannot invoke actions on EC2 instances directly

◆ PAUSE AND DECIDE

What is the BEST assessment?

- A

 Sound – fastest containment
Confuses containment with eradication. Termination is eradication, and doing it first destroys memory, disk and the answer to how they got in.
- B

 Sound if limited to CRITICAL only
The tempting middle. It reduces the false positive rate without changing anything: evidence is still destroyed, and the DoS trigger still exists at a higher severity.
- C

 Unsound – destroys evidence and creates a DoS trigger
Correct. Both flaws are real and neither is fixable by tuning. Isolate to a forensic security group and snapshot, then decide about termination.
- D

 Unsound – EventBridge cannot act on EC2
Factually wrong. EventBridge invokes Lambda, Automation and Step Functions, any of which can terminate an instance. Right verdict, invented reason.

THE SIGNAL

In an autoscaled fleet, terminating the instance also removes it from the ASG – which cheerfully launches a replacement into the same attack.

Five things to carry forward

- ◆ **Automate the runbook, support the playbook.** Steps automate; judgement does not.
- ◆ **OpsCenter, not Incident Manager** – which closed to new customers in November 2025.
- ◆ **Lambda = one action. Automation = one procedure. Step Functions = a workflow.**
- ◆ **SageMaker AI notebooks are named in skill 2.1.1** – reasoning, queries and charts together.
- ◆ **'Automatically terminate' is almost always wrong.** Isolate and snapshot first.

ON THE EXAM

Next: preparing before the incident – access, blast radius, and Shield Advanced.